Middle Mayhem – SOC Investigation

1. Executive Summary

A multi-stage attack was identified targeting a web application running a vulnerable Next.js framework. The attacker conducted high-volume reconnaissance, leveraged an authorization bypass vulnerability (**CVE-2025-29927**) using a crafted header, achieved remote code execution via file upload, and performed lateral movement through SSH brute-force, ultimately compromising the **`dbserve`** account.

This investigation demonstrates full attack life-cycle reconstruction and highlights gaps in application security, monitoring, and network controls.

1.1 Vulnerability Context

CVE-2025-29927 is a critical authorization bypass vulnerability (CVSS 9.1) disclosed in March 2025 affecting self-hosted Next.js applications. Next.js middleware uses an internal header called `x-middleware-subrequest` to track recursive subrequests and prevent infinite loops during rewrites. However, in vulnerable versions, the framework blindly trusts this header without verifying its origin. By including this header with the appropriate value in an external request, an attacker can trick the server into believing middleware has already executed, causing it to skip all middleware-based security checks — including authentication and authorization — and forward the request directly to protected routes. Affected versions span Next.js 11.1.4 through 15.2.2. Patched versions introduced a cryptographic server-side token to validate the header's legitimacy.

---

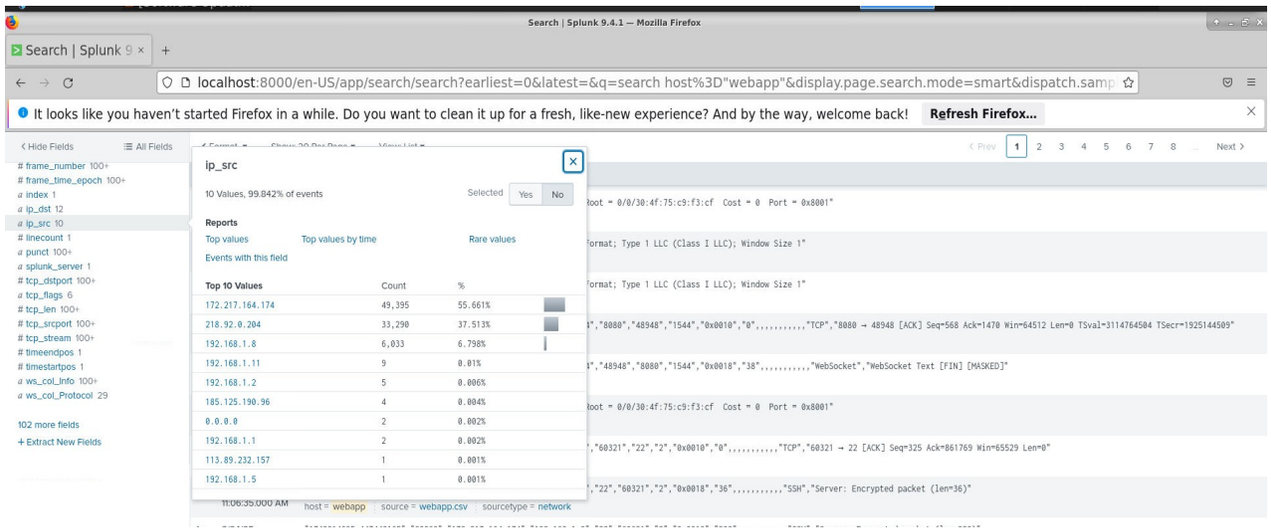
2. Alert Trigger & Initial Triage

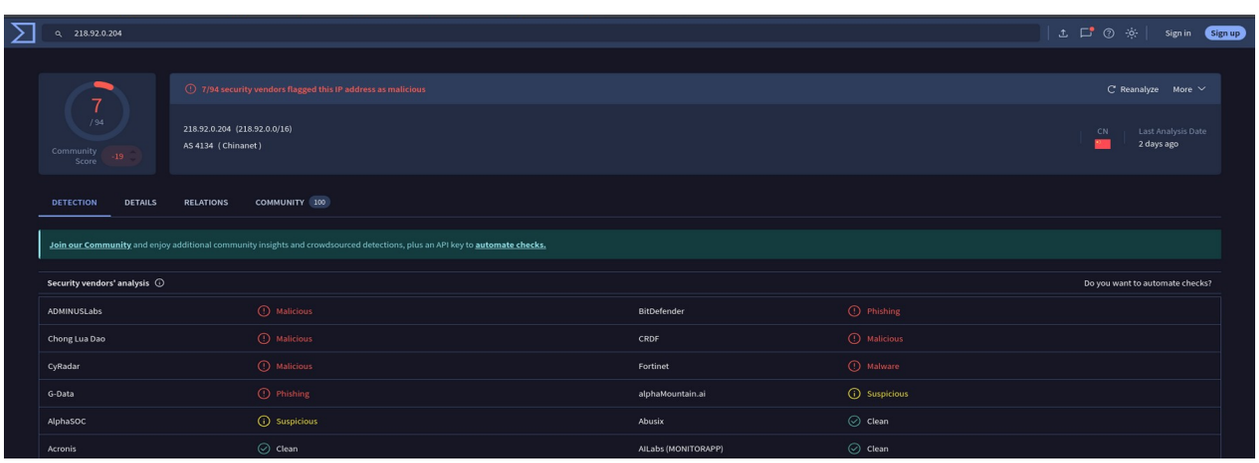
2.1 Trigger

- High volume of HTTP requests observed from a single external IP

Initial Query

```
index=* host="webapp"
| stats count by ip_src
| sort -count
```





Findings

- IP `218.92.0.204` generated abnormally high traffic
- Traffic volume significantly exceeds baseline → possible automated activity

Next Steps

- Pivot to URI-level analysis to confirm enumeration behavior

---

3. Investigation

3.1 Reconnaissance

index=* host="webapp" ip_src="218.92.0.204"
| stats count by http_request_uri

Findings

- ~9,930 unique URIs requested
- A **high proportion of HTTP 404 responses** was observed, consistent with directory enumeration activity.
- **Automated scanning** (tools like dirsearch/gobuster)
- Attacker mapping application structure

Next Steps

- Check for discovery shortcuts → examined `/robots.txt`

3.2 Discovery via robots.txt

Findings

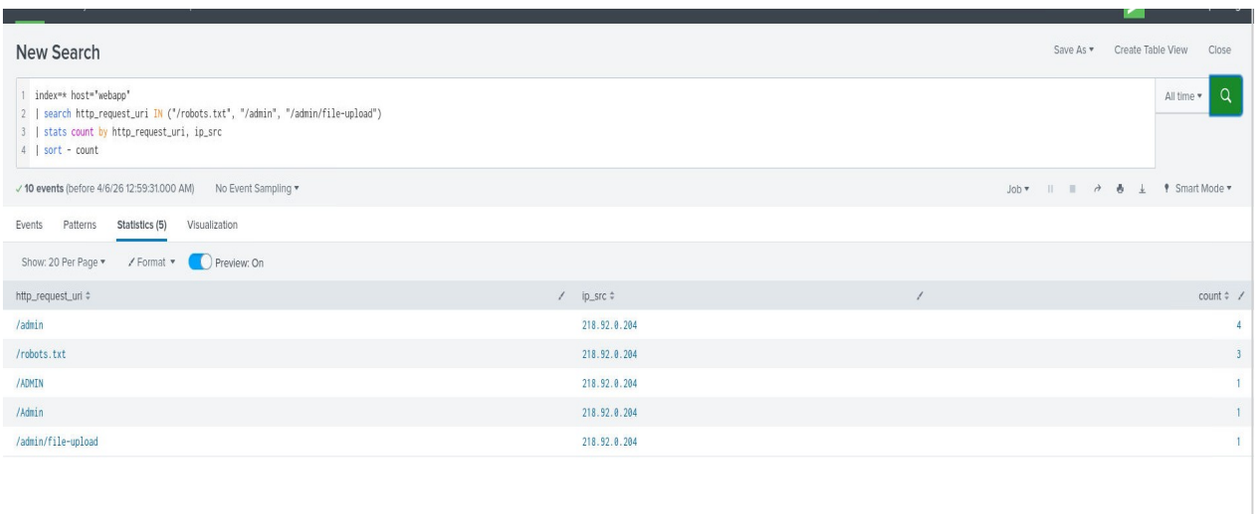
- Sensitive endpoints exposed:
  - `/admin`
  - `/admin/file-upload`

Analysis

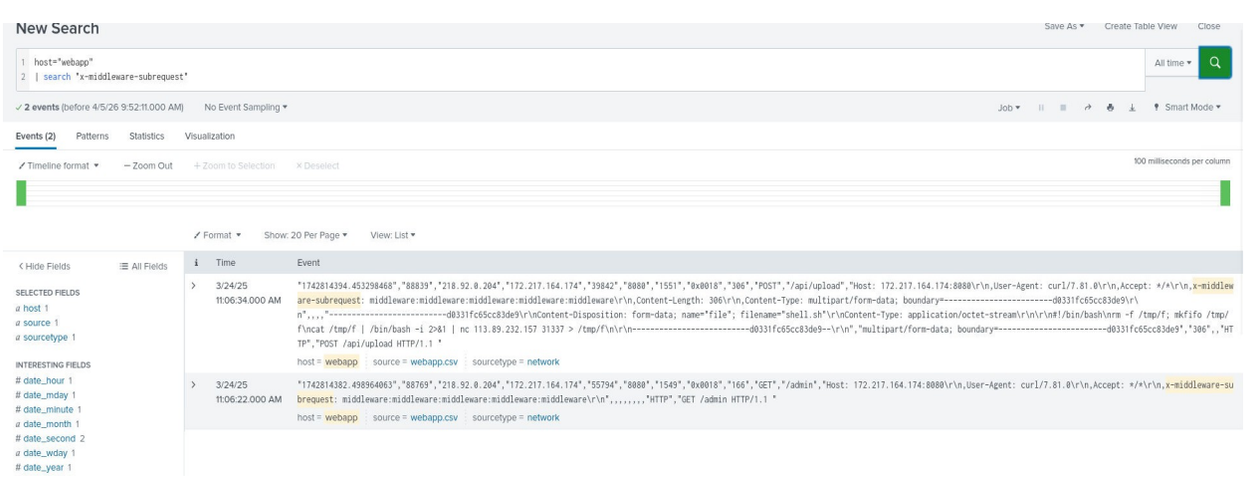
- Application unintentionally disclosed high-value endpoints

Next Steps

- Pivot to check access logs for `/admin` and upload endpoints



3.3 Exploitation – Authentication Bypass



Findings

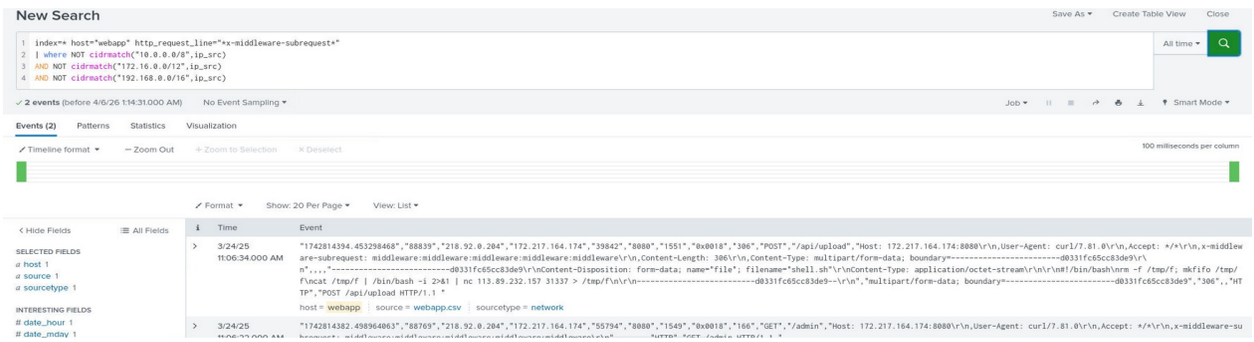
- Header `x-middleware-subrequest` present in requests
- Abuse of internal middleware trust mechanism

Analysis

- The middleware header tricks Next.js into treating an external request as an internal subrequest, bypassing auth checks

Next Steps

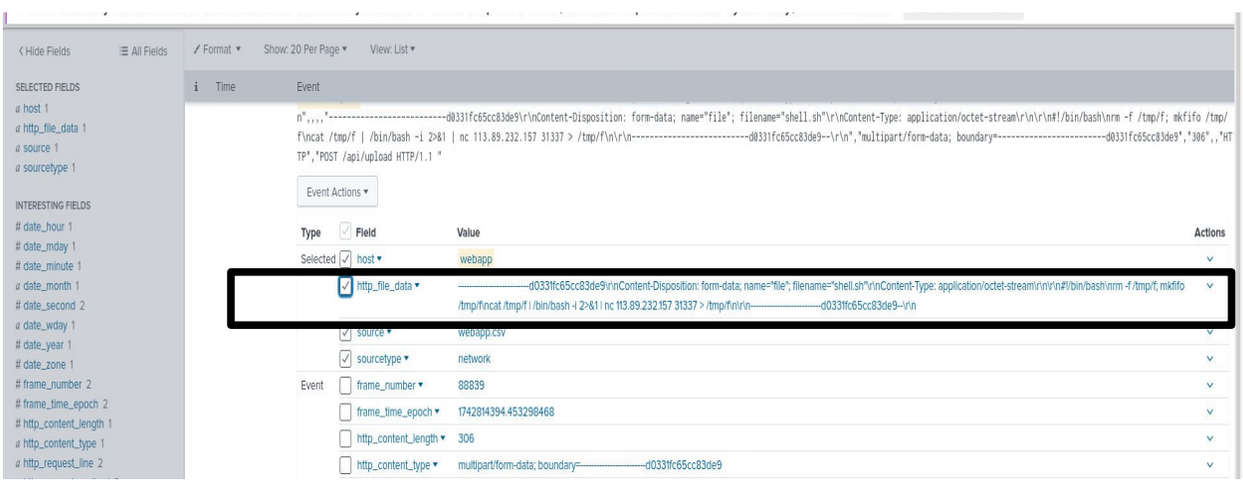
- Check post-authentication endpoints accessed by attacker.
- Filtering out internal RFC 1918 address space to isolate external sources abusing the internal header



3.4 Remote Code Execution (RCE)

Findings

- Endpoint accessed: `/api/upload`
- File uploaded: `shell.sh`
- Reverse shell initiated:
  - `113.89.232.157:31337`

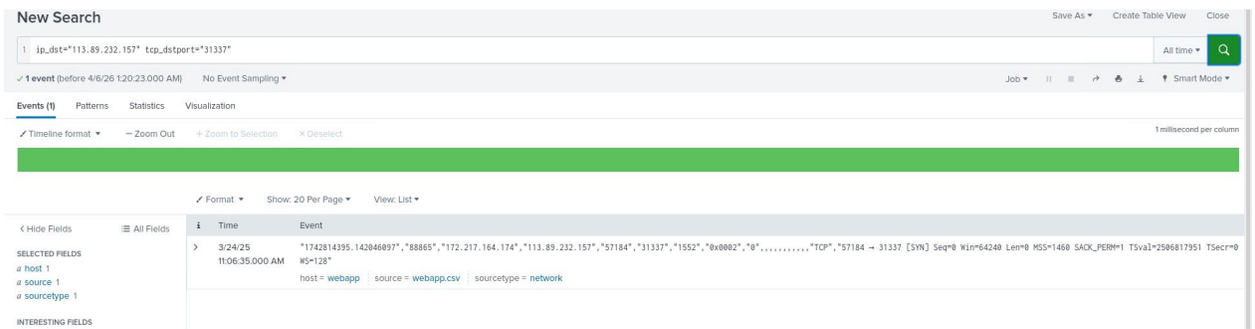


Analysis

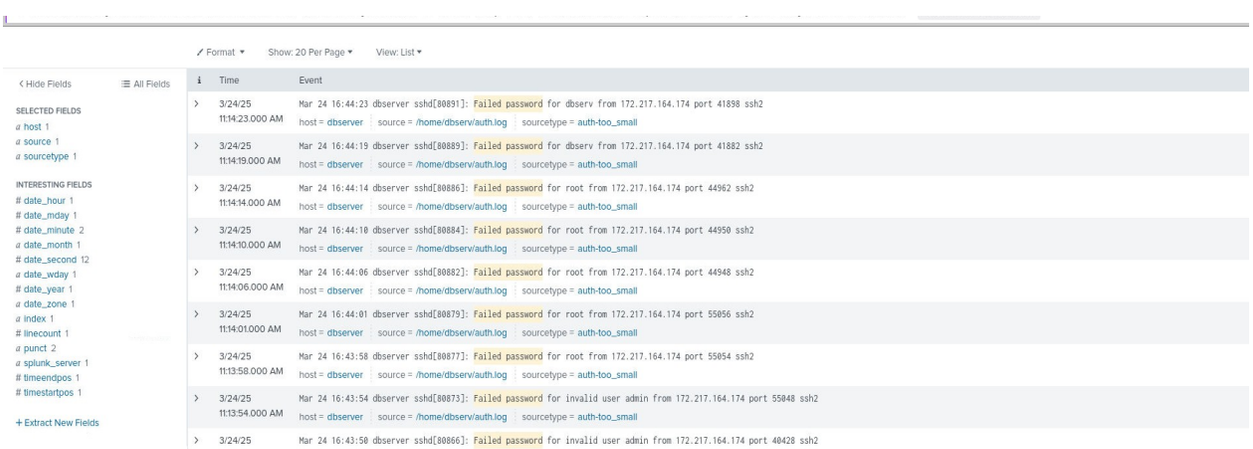
- The upload endpoint accepted arbitrary file types without validation, the shell payload used bash and netcat. This shows the server had no application sand boxing.
- The outbound traffic on port 31337 was permitted. Indicates no egress filtering

Next Steps

- Investigate outbound connections and payload behavior

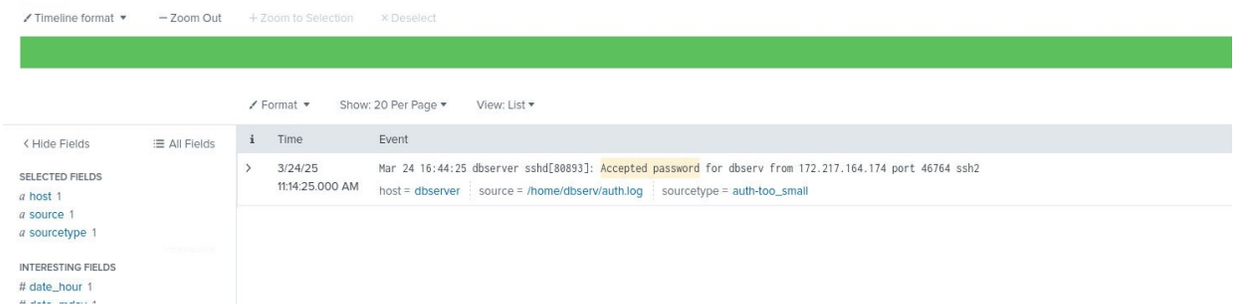


3.5 Lateral Movement (SSH)



Findings

- Multiple failed SSH login attempts
- User: `dbserve`



Findings

- Login success for user dbserve.
- Credential brute-force succeeded
- Attacker expanded beyond initial host

---

4. Timeline of Events

Start Time	End Time	Event Description	Source IP / Indicator	SOC Interpretation
24/03/2025 11:03:16	24/03/2025 11:06:41	High-volume web traffic detected	218.92.0.204	Automated reconnaissance / scanning activity
24/03/2025 11:03:27	—	robots.txt accessed	218.92.0.204	Discovery of sensitive endpoints
24/03/2025 11:04:00	—	/admin and /admin/file-upload accessed	218.92.0.204	Targeting high-value application endpoints
24/03/2025 11:06:22	—	x-middleware-subrequest header observed	218.92.0.204	Exploitation of authentication bypass vulnerability
24/03/2025 11:06:34	—	/api/upload endpoint triggered	218.92.0.204	Attempt to upload malicious payload
24/03/2025 11:06:35	—	Reverse shell established	113.89.232.157:31337	Remote command execution / C2 established

Start Time	End Time	Event Description	Source IP / Indicator	SOC Interpretation
24/03/2025 11:13:36	—	SSH brute-force attempts begin	218.92.0.204	Lateral movement attempt
24/03/2025 11:14:25	—	Successful login as dbserve	Internal system	Credential compromise confirmed

---

5. IOC Table

Indicator Type	Value	Context	Confidence
IP Address	218.92.0.204	Reconnaissance scanning	High
IP Address	113.89.232.157	Reverse shell C2	High
Port	31337	C2 communication	High
File	shell.sh	Reverse shell payload	High
Header	x-middleware-subrequest	Exploit indicator	High
Username	dbserve	Compromised account	Medium

---

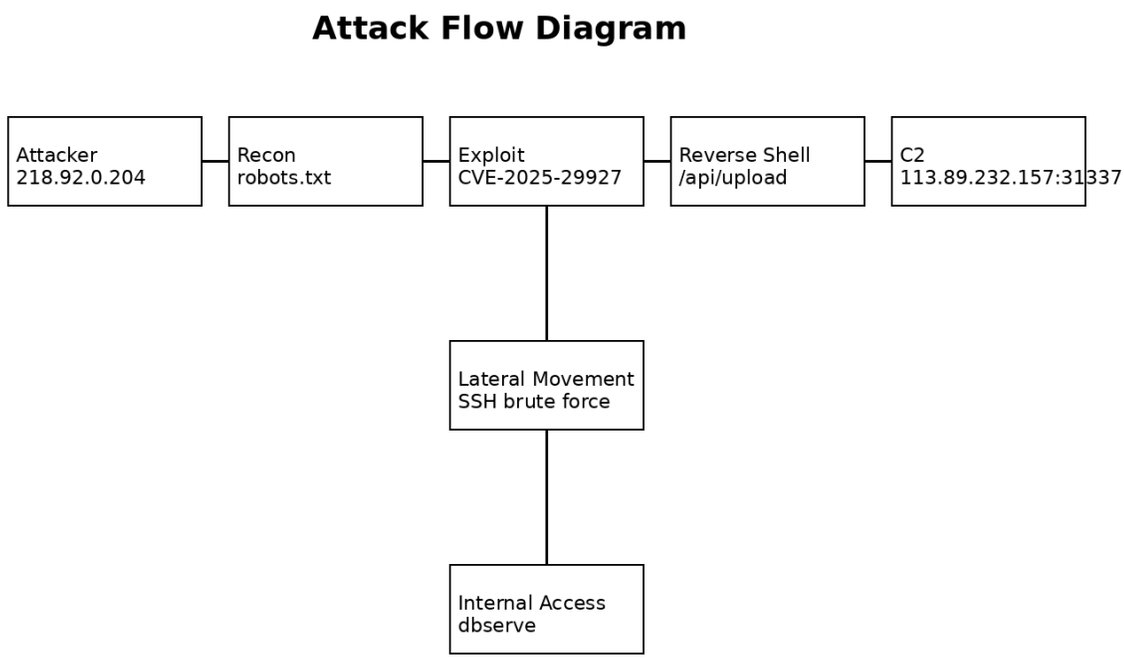
6. MITRE ATT&CK Mapping

Technique	ID	Description
Active Scanning	T1595	Endpoint enumeration
Exploit Public-Facing App	T1190	Next.js vulnerability
Unix Shell	T1059.004	Reverse shell execution
SSH Lateral Movement	T1021.004	Internal access

Technique	ID	Description
Brute Force	T1110	Password guessing

---

7. Attack Flow



8. Impact Assessment

Confirmed Impact

- Unauthorized admin access
- Remote command execution
- Internal account compromise

Potential Impact

- Compromise of the dbserve account suggests potential access to backend database services, increasing the risk of sensitive data exposure.
- Persistence mechanisms

---

9. Remediation & Recommendations

Remediation

Containment Actions:

- Block malicious IPs at firewall
- Disable compromised account (dbserve)
- Isolate affected host from network

Recommended Fixes

Critical - Immediate Fix

- Patch vulnerable Next.js middleware (CVE-2025-29927)
- Deploy outbound firewall rules blocking uncommon ports (e.g., 31337)
- Enforce SSH key-based authentication (disable password auth)

High Priority Fix

- Remove sensitive endpoints from `robots.txt`
- Implement rate limiting on `/api/upload`
- Implement WAF rules for header validation

Medium Priority Fix

- Create SIEM alerts for:
    - High URI enumeration
    - Internal header abuse
    - Reverse shell indicators

---

10. Detection Engineering

Alert 1: High-Volume URI Enumeration (Directory Brute-Force Detection)

Severity: Medium (escalate to High if 200-status responses confirm successful endpoint discovery)

Objective: Detect automated directory brute-forcing and path enumeration against web applications. Attackers use tools like dirsearch, gobuster, and ffuf to systematically probe for hidden endpoints, admin panels, configuration files, and backup directories. This activity is typically the first stage of an attack chain and, if successful, directly informs the attacker's exploitation strategy — as observed in this investigation where robots.txt disclosure led to admin panel access.

Trigger Condition: More than 500 unique URIs requested by a single source IP within a 60-minute window. In this investigation, the attacker generated approximately 9,930 unique URIs in under 4 minutes — roughly 40 requests per second — which is far beyond any legitimate browsing pattern. The 500-URI threshold provides a conservative baseline that catches scanning while avoiding false positives from crawlers or heavy API consumers.

Why These Thresholds: Normal user sessions rarely exceed 20–50 unique URIs. Authenticated API clients and monitoring tools may reach 100–200 in high-traffic environments. Anything above 500 unique URIs from a single source in under an hour is almost certainly automated. The `requests_per_second` calculated field helps distinguish aggressive scanning (>10/sec) from slower, evasive enumeration (<1/sec) — both are malicious, but the latter suggests a more sophisticated attacker attempting to avoid detection.

Expected False Positive Rate: Low to moderate. Known sources of benign high-URI traffic include legitimate search engine crawlers (Googlebot, Bingbot — verify against published IP ranges), internal vulnerability scanners and penetration testing tools (should be whitelisted by IP or scheduled window), and uptime monitoring services hitting multiple endpoints. Maintaining a whitelist of approved scanners and crawler IP ranges significantly reduces noise.

Alert 2: Middleware Header Abuse (CVE-2025-29927)

Severity: High

Objective: Detect external requests containing the `x-middleware-subrequest` header, which is an internal Next.js framework header that should never appear in client-originated traffic. Its presence from an external source is a strong indicator of attempted authentication bypass via CVE-2025-29927.

Trigger Condition: Any single occurrence from a non-RFC 1918 source. This is a zero-tolerance indicator — there is no legitimate reason for an external client to send this header.

Expected False Positive Rate: Very low. The only known benign scenario is Vercel-hosted deployments where the platform injects session metadata into this header. Self-hosted environments should never see it from external traffic.

Alert 3: Reverse Shell Detection (Outbound C2 on Non-Standard Ports)

Severity: Critical

Objective: Detect outbound connections from web-facing servers to external IPs on ports commonly associated with reverse shells and C2 frameworks. Web servers should only initiate outbound traffic to known services (DNS, NTP, package repos). Any other outbound connection — especially to high or non-standard ports — is a strong post-exploitation indicator.

Trigger Condition: Any outbound connection from the web server to a non-RFC 1918 IP on a port outside the approved allow list (80, 443, 53, 123, 25, 587). Environments with stricter baselines should reduce this allow list further.

Key Indicators in This Investigation: Port 31337 is a well-known backdoor/C2 port (historically associated with Back Orifice and commonly used in CTF/red team tooling). A production web server connecting outbound to this port is near-certain confirmation of compromise.

Expected False Positive Rate: Low to moderate, depending on environment. Legitimate outbound traffic that could trigger this includes health checks to external APIs, webhook callbacks, or package manager updates on non-standard ports. Baseline normal outbound traffic for the specific host over 7–14 days before deployment will reduce false positives.